

Informe Técnico de Seguridad: Inyección SQL

Título del Hallazgo

Inyección SQL en el campo de búsqueda del módulo de información de usuario

Descripción

Durante una auditoría de seguridad realizada en el entorno de laboratorio DVWA (Damn Vulnerable Web Application), se identificó una vulnerabilidad de tipo inyección SQL en el campo de búsqueda asociado al parámetro `id` del módulo SQL Injection. El sistema no valida adecuadamente los datos ingresados por el usuario antes de procesarlos en la base de datos, lo que permite a un atacante modificar la lógica de las consultas SQL ejecutadas en el servidor. Esta omisión facilita el acceso no autorizado a información almacenada, comprometiendo la confidencialidad de los datos.

Evidencia Técnica

El campo vulnerable corresponde al parámetro `id` enviado mediante el método GET en el formulario de búsqueda del módulo SQL Injection.

Se utilizó el siguiente payload como prueba de concepto:

```
1' OR '1'='1
```

Este valor fue introducido directamente en el campo de búsqueda y enviado al servidor. Como resultado, la aplicación devolvió un listado completo de usuarios almacenados en la base de datos, en lugar de mostrar únicamente el registro correspondiente al ID ingresado. Este comportamiento demuestra que la consulta SQL original fue alterada, generando una condición verdadera que omite cualquier restricción de filtrado.

Visualmente, el navegador mostró una tabla con múltiples registros de usuario, lo que permite inferir que la lógica de control de acceso fue evadida y que los datos expuestos podrían contener información sensible como nombres, correos o identificadores internos.

Evaluación del Riesgo

La vulnerabilidad detectada se clasifica con un nivel de riesgo alto, dado su impacto potencial en la confidencialidad de los datos y la facilidad con la que puede ser explotada.

De no ser mitigada, esta falla puede conducir a la extracción masiva de información de usuarios, acceso no autorizado a bases de datos completas, exposición de credenciales o

incluso a la ejecución de comandos más peligrosos que alteren la integridad de los datos o comprometan otros sistemas relacionados.

Recomendación Técnica

Para mitigar esta vulnerabilidad se recomienda implementar sentencias preparadas (prepared statements) en todas las interacciones entre la lógica de negocio y la base de datos. Este enfoque asegura que los datos ingresados por el usuario sean tratados como parámetros y no como parte del código SQL ejecutable.

Adicionalmente, se debe aplicar una validación robusta del lado del servidor, sanitizando todas las entradas provenientes de formularios, URLs y cabeceras. Estas validaciones deben contemplar tanto el tipo de dato como su formato esperado.

Se aconseja complementar la defensa con un firewall de aplicaciones web (WAF) capaz de detectar y bloquear patrones comunes de inyección SQL en tiempo real. Finalmente, se deben realizar pruebas de seguridad periódicas utilizando herramientas especializadas como Burp Suite, Sqlmap y análisis manual, a fin de identificar posibles regresiones o nuevas superficies de ataque.

Reflexión Final

Una documentación clara y estructurada permite al equipo de desarrollo comprender con exactitud el origen del problema, las condiciones bajo las cuales se presenta y las acciones necesarias para corregirlo. Al evitar ambigüedades y utilizar un lenguaje técnico accesible, se facilita también la comunicación con otros actores del proyecto, como gerentes de producto o responsables de cumplimiento. La claridad en la documentación no solo acelera la solución, sino que contribuye a la construcción de software más seguro desde sus cimientos.